

THIRD-PARTY SYNTHETIC MONITORING AGREEMENT

Continuous Security Assurance Addendum

1. Parties and Definitions

This Third-Party Synthetic Monitoring Agreement (“Agreement”) is entered into between:

Client (“Monitoring Party”):	_____
Provider (“Monitored Party”):	_____
Effective Date:	_____
Master Agreement Reference:	_____

For purposes of this Agreement, the following definitions apply:

- “Synthetic Monitoring” means the automated, non-intrusive external verification of security posture indicators on publicly accessible endpoints, performed without access to internal systems, source code, or infrastructure.
- “Monitored Surface” means the set of URLs and endpoints listed in Schedule A that the Provider exposes to the Client in the context of the contracted service.
- “Security Headers” means HTTP response headers configured to instruct browsers and clients on security-relevant behavior, including but not limited to HSTS, X-Frame-Options, X-Content-Type-Options, Content-Security-Policy, and Referrer-Policy.
- “Monitoring Evidence” means timestamped records, logs, and reports generated by the monitoring tool, stored in infrastructure controlled by the Client.

2. Purpose and Scope

This Agreement establishes the Client’s right to conduct continuous, independent synthetic monitoring of the Monitored Surface as a complementary layer of security assurance. This monitoring does not replace, substitute, or supersede any certification, audit report, or attestation (including SOC 2, ISO 27001, or equivalent) provided by the Provider. It operates as an independent, client-controlled verification mechanism aligned with the Client’s third-party risk management obligations.

This Agreement applies exclusively to the external, publicly accessible surface the Provider exposes for the Client’s use. It does not grant the Client access to internal systems, network infrastructure, source code, databases, or any other non-public assets of the Provider.

3. Monitored Surface

The endpoints subject to monitoring under this Agreement are listed in Schedule A. The Monitored Surface is limited to URLs and endpoints that:

- Are publicly accessible via HTTPS;
- Are exposed by the Provider specifically for the Client's use under the Master Agreement; and
- Do not require authentication credentials, privileged access, or bypass of security controls to reach.

The Provider shall notify the Client no less than [] business days in advance of any planned changes to the URLs, domain names, or infrastructure components listed in Schedule A. Emergency changes shall be communicated within [] hours of implementation.

4. Monitoring Criteria

The Client's monitoring tool verifies the following external security indicators on the Monitored Surface. Applicability of each criterion depends on the nature of the endpoint and shall be documented in Schedule A.

Criterion	What is Verified	Applicable To
TLS/Certificate	Protocol version (TLS 1.2 minimum), certificate validity, expiration date, issuer, and chain completeness. The monitoring tool establishes standard HTTPS connections solely to verify certificate parameters and HTTP response headers. It does not decrypt, intercept, or store the content of encrypted communications.	All HTTPS endpoints
Security Headers	Presence and configuration of HSTS, X-Frame-Options, X-Content-Type-Options, CSP, and Referrer-Policy as applicable to the endpoint type.	Web portals, login pages, API gateways
Availability / Uptime	HTTP response code, endpoint reachability, and compliance with contractual SLA thresholds.	All endpoints
Response Time (TTFB)	Time to First Byte measured at defined intervals to detect degradation patterns.	All endpoints
Content Integrity	Detection of unexpected structural changes to endpoint responses that may indicate unauthorized modification.	Portals, dashboards, public API responses

The above criteria represent the maximum scope of external verification. The Client shall not use the monitoring tool to attempt authentication bypass, enumerate internal resources, conduct penetration testing, or perform any activity beyond passive observation of publicly accessible responses.

5. Provider Obligations

5.1 Non-Interference

The Provider agrees not to block, throttle, or otherwise interfere with monitoring traffic originating from IP addresses or user-agent strings disclosed by the Client, provided such traffic conforms to the frequency and scope defined in Schedule B. Any security control (WAF rule, rate limiter, IP block) that would affect monitoring traffic shall be implemented only after providing [] business days' written notice to the Client.

5.2 Change Notification

The Provider shall notify the Client of planned changes that may affect monitoring results, including: infrastructure migrations, domain changes, certificate renewals (when renewal results in issuer or key changes), and modifications to HTTP security header configurations.

5.3 Incident Cooperation

In the event the monitoring tool detects an anomaly (certificate expiration, header removal, availability degradation, or content change), the Provider agrees to cooperate with the Client's investigation within [] business hours of notification.

5.4 Anomaly Notification

Upon detection of a monitoring anomaly, the Client may notify the Provider's designated escalation contact identified in Schedule B. Notification may include the affected endpoint, the nature of the anomaly detected, and the timestamp of detection.

6. Monitoring Evidence and Data Handling

All Monitoring Evidence is collected and stored exclusively within Client-controlled infrastructure. The following data handling principles apply:

- Monitoring Evidence is the property of the Client and constitutes part of the Client's third-party risk management records.
- Evidence is retained for a minimum of [] days, consistent with the Client's record retention policy and applicable regulatory obligations.
- The monitoring tool does not collect, store, or transmit personal data, authentication credentials, session tokens, or any data contained within authenticated responses. The monitoring tool establishes standard HTTPS connections solely to verify certificate parameters and HTTP response headers; it does not decrypt, intercept, or store the content of encrypted communications.
- Monitoring Evidence may be used in audit contexts, regulatory inquiries, or contractual dispute resolution as documentation of observed security posture.

Monitoring Evidence constitutes the Client's independent record of the externally observable state of the Monitored Surface at the time of collection and does not constitute a security assessment of the Provider's internal controls.

7. Limitations and Exclusions

Important: Scope of This Agreement

Synthetic monitoring as defined herein is an external, passive observation mechanism. It does not constitute and shall not be construed as:

- A security audit, penetration test, or vulnerability assessment;
- An evaluation of the Provider's internal controls, processes, or governance practices;
- A substitute for SOC 2, ISO 27001, or other third-party audit certifications; or
- Legal advice or a determination of regulatory compliance.

Findings from synthetic monitoring represent observed external indicators only. The absence of detected anomalies does not guarantee the absence of internal security vulnerabilities or control failures.

8. Term and Termination

This Agreement is coterminous with the Master Agreement referenced in Section 1 and terminates automatically upon expiration or termination of that agreement, unless separately extended in writing by both parties.

Either party may request modification of the Monitored Surface or monitoring criteria by providing written notice. Modifications take effect upon mutual written agreement.

Upon termination, the Client retains all Monitoring Evidence collected during the term of this Agreement.

9. Signatures

By signing below, the parties agree to the terms of this Third-Party Synthetic Monitoring Agreement.

CLIENT (Monitoring Party)	PROVIDER (Monitored Party)
Signature: _____	Signature: _____
Name & Title: _____	Name & Title: _____
Date: _____	Date: _____

SCHEDULE A — Monitored Surface

List all endpoints subject to monitoring under this Agreement. For each endpoint, indicate which criteria from Section 4 apply.

Endpoint URL	TLS/Cert	Sec. Headers	Availability	Content Integrity	
	☐	☐	Yes / N/A	☐	
	☐	☐	Yes / N/A	☐	
	☐	☐	Yes / N/A	☐	
	☐	☐	Yes / N/A	☐	
	☐	☐	Yes / N/A	☐	
	☐	☐	Yes / N/A	☐	
	☐	☐	Yes / N/A	☐	
	☐	☐	Yes / N/A	☐	
	☐	☐	Yes / N/A	☐	
	☐	☐	Yes / N/A	☐	
	☐	☐	Yes / N/A	☐	
	☐	☐	Yes / N/A	☐	

SCHEDULE B — Monitoring Parameters and Technical Specifications

The following technical parameters define the authorized monitoring behavior:

Parameter	Value / Description
Monitoring Frequency	[] minutes between checks per endpoint
Source IP Range / Agent	To be disclosed by Client upon request and updated as needed
HTTP Method	GET only — no POST, PUT, DELETE, or authenticated requests
User-Agent String	[Client-defined identifier, e.g., 'GRC-SyntheticMonitor/1.0']
Request Volume (max)	[] requests per endpoint per hour
Evidence Storage Location	Client-controlled AWS S3 bucket — not accessible to Provider
Alert Recipients (Client side)	[Client-defined — email addresses or notification endpoints]
Escalation Contact (Provider)	Name: _____ Email: _____ Phone: _____
Anomaly Notification Deadline	At Client's discretion — no mandatory deadline

The Client's monitoring tool operates as a read-only, external observer. It does not authenticate, submit forms, execute scripts, or interact with the Provider's application layer beyond issuing standard HTTP GET requests to the URLs listed in Schedule A.